

VMware STIG Tools Appliance

Updated: 2025-08018

Review the “VMware_STIG_Tools_Appliance_Cheat_Sheet.pdf” for deployment details.

Review the “VMware_STIG_Tools_Appliance_FAQ.pdf” for further information.

The intent for this hardened appliance is that it is disposable as it has installed tooling that could be harmful to your environment if mis-used in-appropriately. It can be re-installed as and when needed.

Installation:

Pre-requisite Information:

- vSphere 7 or newer environment.
- 2 vCPUs
- 8GB Memory
- 50GB Storage+5GB+5GB (3 vmdks)
- 1 Static IP address or DHCP assigned IP Address.
- Lowercase Hostname
- Forward and Reverse DNS Lookups
- New root password that meets the complexity requirements (15 characters min and 1 of each character class)
- Subnet, Default Gateway, DNS Domain Name and Server Ips
 - **NOTE:** Subnet must be a PREFIX reference (i.e. 24) not an Octet reference (i.e. 255.255.255.0)
- Management/jump server with SSH (port 22) access to the STIG Tools Appliance
- Management/jump server with WINSCP or similar to be able to transfer files to and from the STIG Appliance (port 22)
- Management/jump server with HTTP (port 80) and HTTPS (port 443) access to the STIG Appliance.
- User access to target vSphere environment to be able to deploy the STIG Tools Appliance.
- Credentialed access to targeted environment. Ideally the following
 - administrator@vsphere.local
 - root
 - admin
 - vcfadmin
 - etc

- Management/Jump server or analyzing workstation has the DoD STIG Viewer (<https://www.cyber.mil/stigs/srg-stig-tools/>) installed to review the checklist output content once copied from the appliance.

Installation notes:

Deploy OVF Template

- 1 Select an OVF template
- 2 Select a name and folder
- 3 Select a compute resource
- 4 Review details**
- 5 Select storage
- 6 Select networks
- 7 Customize template
- 8 Ready to complete

Review details

Verify the template details.

⚠ The OVF package contains advanced configuration options, which might pose a security risk. Review the advanced configuration options below. Click next to accept the advanced configuration options.

Publisher	No certificate present
Product	VMware STIG Tools Appliance
Version	9.0.0.0
Vendor	Broadcom Inc.
Description	VMware STIG Tools Appliance
Download size	1.8 GB
Size on disk	5.5 GB (thin provisioned) 60.0 GB (thick provisioned)
Advanced configuration	RemoteDisplay.maxConnections = 1

Uncheck the “Enable DOD banner” if not a US DoD Environment and make sure you comply with the **password requirements**

Customize template

Customize the deployment properties of this software solution.

⚠ 1 property has an invalid value

Application		3 settings
Hostname	The hostname for this VM. Leave blank to try to reverse lookup the IP address. 	
Initial root password	This will be used as an initial password for the root user account. Password Confirm Password ⓘ ⓘ Password must be at least 15 characters and at most 32 characters.	
Enable DOD banner	Enable the Standard Mandatory DOD Notice and Consent Banner ☒	

Networking Properties		6 settings
Select Network Mode	Select the network mode for this VM: static or dhcp. static ▼	
Network 1 IP Address	The IP address for this interface. Leave blank if DHCP is desired. _____	
Network 1 IP Subnet Prefix	The subnet prefix for this interface. i.e 24. Leave blank if DHCP is desired. _____	
Default Gateway	The default gateway address for this VM. Leave blank if DHCP is desired. _____	
Domain Name Servers	The domain name server IP Addresses for this VM (comma separated). Leave blank if DHCP is desired. _____	
DNS Domains	Any local DNS search domains for the local network (comma separated). Leave blank if DHCP is desired. _____	

In some cases, the appliance may deploy and the OVF parameters entered above may not be set correctly after deployment. Do check the vApp parameters entered especially the **Subnet Prefix** entry.

Review the vApp Options (VM → Configure → vApp Options → Properties) are entered correctly and power on the VM.

Settings

VM SDRS Rules

vApp Options

Alarm Definitions

Scheduled Tasks

Policies

VMware EVC

Guest User Mappings

Disabled Methods

OVF environment transport

VMware Tools

Installation boot

Disabled

Properties

ADD

EDIT

SET VALUE

DELETE

	Key	Label	Value	Default Value	Category	Type
	network.gateway.VMware_STIG_Tools_Appliance	Default Gateway			Networking Properties	string
	network.netprefix0.VMware_STIG_Tools_Appliance	Network 1 IP Subnet Prefix	24		Networking Properties	string
	network.dnsdomains.VMware_STIG_Tools_Appliance	DNS Domains			Networking Properties	string
	hostname	Hostname			Application	string
	varoot-password	Initial root password	*****	*****	Application	password(15..32)
	network.dns.VMware_STIG_Tools_Appliance	Domain Name Servers			Networking Properties	string
	vm.vmname	vmname		VMware_STIG_Tools_Appliance		string
	network.ip0.VMware_STIG_Tools_Appliance	Network 1 IP Address			Networking Properties	string
	network.netmode.VMware_STIG_Tools_Appliance	Select Network Mode	static	dhcp	Networking Properties	string["static", "dhcp"]

Do check for any spaces before and after the Value and that the Subnet Prefix is set correctly.

If you are able to connect via the Web or Remote Consoles and successfully login as “root” then you may be able to reset the IP Address using the following commands (https://vmware.github.io/photon/assets/files/html/3.0/photon_admin/setting-a-static-ip-address.html) then navigate to the appliance VAMI page (<https://<FQDN>:5480>) and set the IP address again to be sure.

The screenshot shows the VMware STIG Tools Appliance Management web interface. The left sidebar contains a navigation menu with the following items: Summary, Monitor, Access, Networking (highlighted), Firewall, Time, Syslog, and Configuration. The main content area is titled 'Network Settings' and includes an 'EDIT' link in the top right corner. It contains two sections: 'NIC 0' and 'Proxy Settings'. The 'NIC 0' section has the following fields: Hostname, DNS Servers, Status (Up), MAC Address, IPv4 Address (with a dropdown for /24 (Static)), and IPv4 Default Gateway. The 'Proxy Settings' section has the following fields: HTTPS, HTTP, and FTP, all of which are set to 'Disabled'. There is also an 'EDIT' link in the top right corner of the 'Proxy Settings' section.

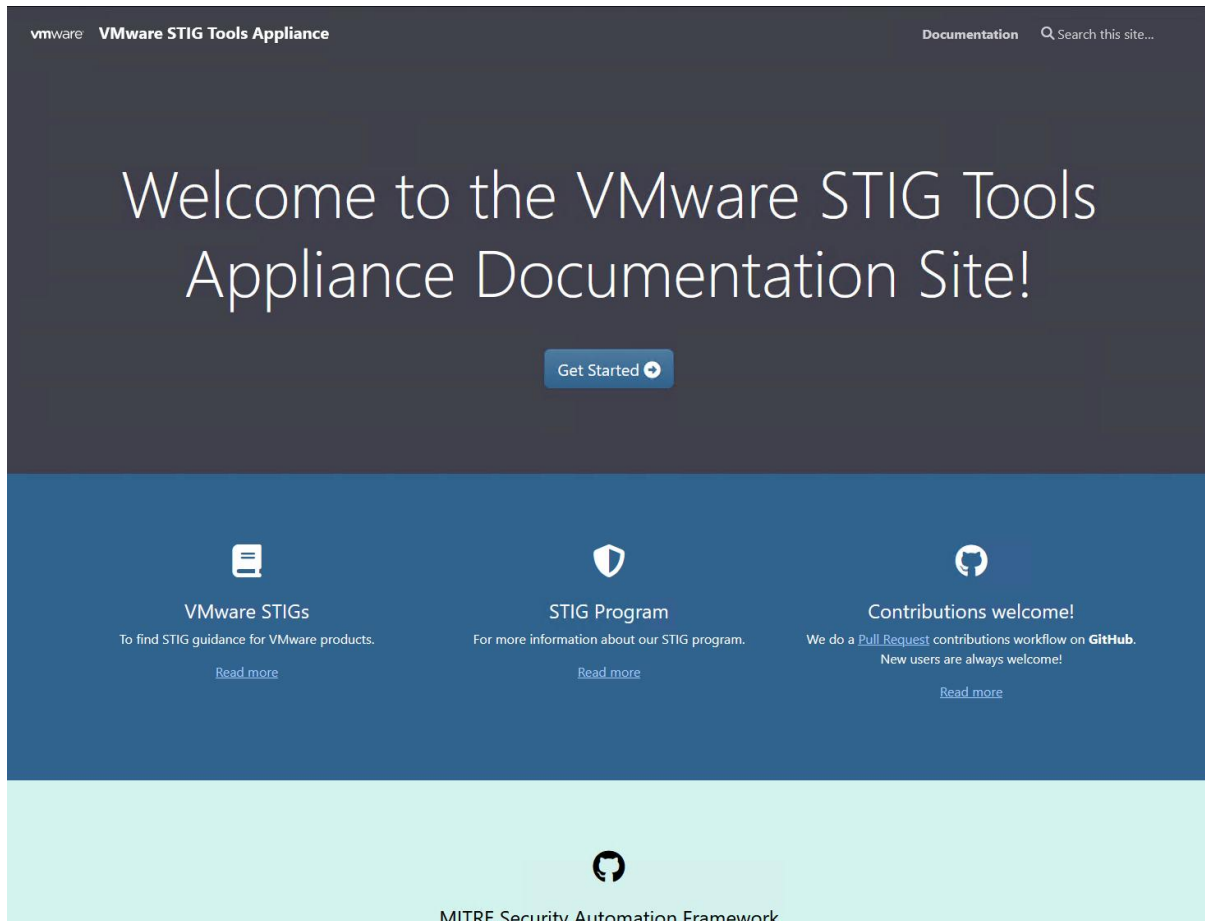
Network Settings		EDIT
Hostname		
DNS Servers		
NIC 0		
Status	Up	
MAC Address		
IPv4 Address		/ 24 (Static)
IPv4 Default Gateway		
Proxy Settings		EDIT
HTTPS	Disabled	
HTTP	Disabled	
FTP	Disabled	

Just click ok and it may indicate that the IP address could not be set.

In most cases, a delete of the VM and a re-deploy would be faster once the input parameters have been re-validated. Re-call that this appliance itself is supposed to be disposable and not linger as an active VM in the environment due to the installed tooling.

Usage:

The STIG Tools Appliance has an internally Hosted Documentation website at http://<STIG_FQDN_IP>



Do browse through the website for information on what is included in the appliance and documentation examples on scanning the various VMware appliances with the available STIGs.

Depending on the size of the environment (number of Datacenter Objects, Cluster Objects, Hosts and Virtual Machines) it may be ideal to audit (or remediate) a subset of the environment. Obviously scanning hundreds of hosts and thousands of Virtual machines will take a long time.

Audit Control Reports/findings are based upon the NIST 800-53 set of controls as used by the U.S. Department of Defense. If you use other compliance controls, then you will need to map the output of the relevant NIST control to your applicable control.

More information about the content can be found here: [GitHub - vmware/dod-compliance-and-automation: Security hardening content for VMware solutions to US Department of Defense standards](#)

Example for a vSphere 8u3 Cluster audit

(http://< STIG_FQDN_IP >/docs/tutorials/vsphere/audit8/#auditing-esxi) assume you only want to scan a **particular cluster** in vCenter. In the input-example.yml file located at “/usr/share/stigs/vsphere/8.0/v2r3-stig/vsphere/inspec/vmware-vsphere-8.0-stig-baseline”, specify the content of the file (input-CLUSTER1.yml) and cluster name like so

```
#Filename – input-CLUSTER1.yml
# ESXi
# Choose whether to scan a single host, all hosts in a cluster, or all hosts in vCenter.
vmhostName: "
cluster: 'CLUSTER1'
allesxi: false
# Set to true if hosts are joined to active directory for authentication
adJoined: false
# If ESXi is joined to AD, enter the AD group that has administrative access to ESXi.
adAdminGroup: 'MyAdAdminGroup'
# Enter the environment specific syslog server ESXi should be forwarding logs to
syslogServer: 'tcp://log.test.local:514'
# Enter the environment specific time servers.
esxiNtpServers:
  - 'time-a-g.nist.gov'
  - 'time-b-g.nist.gov'
# Enter the environment specific vMotion VLAN Id.
vMotionVlanId: '100'
# Enter the environment specific Management VLAN Id.
mgtVlanId: '101'
# Enter an array of users that should be in the lockdown mode exceptions list.
exceptionUsers:
  - root
  - dcui
# If snmp is used in the environment change to true.
snmpEnabled: 'false'
# Enter the latest build number for ESXi. Currently 8u3e
esxiBuildNumber: '24674464'
# Enter the approved certificate issuer organization name (issuer_organization field in the
cert).
certificateIssuerOrg: 'YOUR ORG'
```

Use WinSCP to copy the inputs-CLUSTER.yml file to the SITG appliance to the following path:

“/usr/share/stigs/vsphere/8.0/v2r3-stig/vsphere/inspec/vmware-vsphere-8.0-stig-baseline”

Execute the vSphere 8 audit for a cluster

1. SSH to the appliance as root,
2. create the reports folder
 - a. mkdir /root/reports (or /tmp/reports as indicated in the documentation)
 - b. NOTE: Any data in the /tmp/reports folder will be deleted upon reboot of the appliance. If you want to have persist after reboot, move it or direct it elsewhere like “/root/reports”
3. run the powershell cli “pwsh”
4. then change directory to the above path where the inputs-CLUSTER.yml is located
 - a. cd /usr/share/stigs/vsphere/8.0/v2r3-stig/vsphere/inspec/vmware-vsphere-8.0-stig-baseline
5. Set the Connection Environment Variables
 - a. # Note: VISERVER is referencing vCenter and not an ESXi host.
 - b. \$env:VISERVER='<vC_IP>'
 - c. \$env:VISERVER_USERNAME='Administrator@vsphere.local'
 - d. \$env:VISERVER_PASSWORD='<PASSWORD>'
6. Execute the audit commands

```
root@wrkstn2stg [ ~ ]# mkdir reports
root@wrkstn2stg [ ~ ]# pwsh
PowerShell 7.4.7-0-g3027638cc49c7ba2990589c70d3a123d02216294
PS /root> cd /usr/share/stigs/vsphere/8.0/v2r3-stig/vsphere/inspec/vmware-vsphere-8.0-stig-baseline
PS /usr/share/stigs/vsphere/8.0/v2r3-stig/vsphere/inspec/vmware-vsphere-8.0-stig-baseline> $env:VISERVER='10.10.10.10'
PS /usr/share/stigs/vsphere/8.0/v2r3-stig/vsphere/inspec/vmware-vsphere-8.0-stig-baseline> $env:VISERVER_USERNAME='Administrator@vsphere.local'
PS /usr/share/stigs/vsphere/8.0/v2r3-stig/vsphere/inspec/vmware-vsphere-8.0-stig-baseline> $env:VISERVER_PASSWORD='VMware!'
PS /usr/share/stigs/vsphere/8.0/v2r3-stig/vsphere/inspec/vmware-vsphere-8.0-stig-baseline>
```

Audit CLUSTER1 using the following command and then convert to a STIG ckl file for review

```
cinc-auditor exec ./esxi/ -t vmware:// --show-progress --enhanced-outcomes --
input-file ./inputs-CLUSTER1.yml --reporter cli json:/root/reports/CLUSTER1.json
html:/root/reports/CLUSTER1.html
```

```
saf convert hdf2ckl -i /root/reports/CLUSTER1.json -o
/root/reports/CLUSTER1.ckl --hostname <vC_IP> --fqdn <vC_FQDN> --ip <vC_IP>
--mac <vC_MAC>
```

NOTE: The “html:/root/reports/CLUSTER1.html” file is an extra parameter that creates a html version of the json output

Once the “json” and “ckl” files have been generated, use WinSCP to copy them from the STIG Appliance to somewhere you can access them.

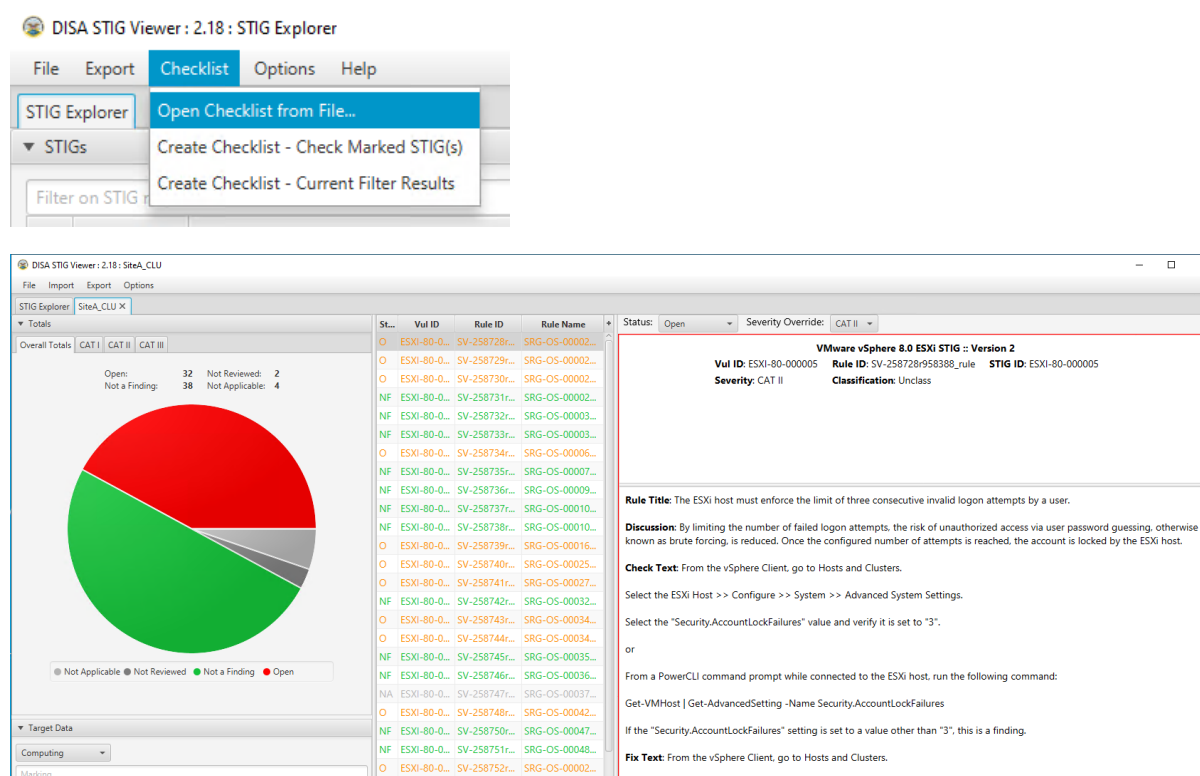
Review the findings using the STIG Viewer 2.18 (<https://www.cyber.mil/stigs/srg-stig-tools/>)

Reviewing the CKL file

There are two ways to review the data, the STIG view and the Heimdall Lite which is built into the appliance

STIG Viewer v2.18

1. Launch the STIG Viewer
2. Click on Checklist
3. Select Open Checklist from File...
4. Select the ckl for analysis.



NOTE1: you can change the status of a control once you have reviewed it.

Save the checklist (File → Save Checklist) once all controls have been reviewed or need to pause the review.

NOTE2: If you change the status of the control, you may also need to change the prefix content in the finding details for the control to be accurately useful when comparing in Heimdall.

The issue is described here: <https://github.com/mitre/heimdall2/issues/6510>

georgedias on Jan 10 · edited by georgedias
Edits
Contributor

Additional information for clarity and understanding on how Heimdall is interpreting the check list (.ckl) status (<STATUS>) tag.
(Anyone: if you belief this to be incorrect please annotate as needed.)

Check List	Heimdall
<STATUS>Open</STATUS>	Failed
<STATUS>NotAFinding</STATUS> with FINDING_DETAILS>passed ::	Passed
<STATUS>NotAFinding</STATUS> with FINDING_DETAILS>any text	Passed
<STATUS>Not_Reviewed</STATUS> with <FINDING_DETAILS>skipped ::	Not Reviewed
<STATUS>Not_Applicable</STATUS> FINDING_DETAILS>skipped ::	Not Applicable

Warning

<STATUS>NotAFinding</STATUS> with FINDING_DETAILS>skipped :: *is not a valid status assigned by Heimdall*

So essentially if you need to change / Update a control using STIG Viewer or editing the file itself, then you also need to update the findings field too to pass the correct information to Heimdall for evaluation / comparison.

i.e. if I am updating control

VCSA-80-000009 from "Open"{STIGViewer}-"Failed"{Heimdall} to "Not a Finding"{STIG Vlewer}-"Passed"{Heimdall}, then you also need to update the Finding for that control by replacing "skipped ::" with either "passed ::" or "any text"

OR

VCSA-80-000024 from "Not Reviewed"{STIGViewer}-"Not Reviewed"{Heimdall} to "Not a Finding"{STIG Vlewer}-"Passed"{Heimdall}, then you also need to update the Finding for that control by replacing "skipped ::" with either "passed ::" or "any text"

i.e. like the following

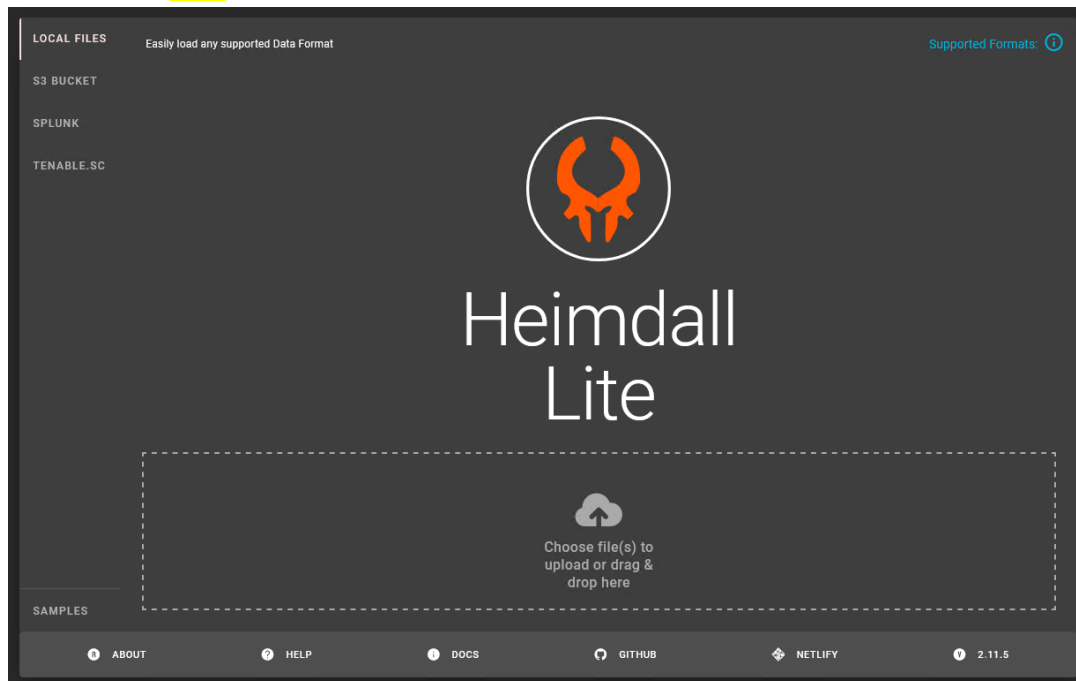
skipped :: TEST This check is a manual

passed :: TEST This check is a manual

Heimdall Lite

The appliance now has Heimdall Lite inbuilt into the appliance as of the 9.0.0.0-24828798 release. This allows a consultant to quickly compare the audited data, however this is the lite version in that the data is non-persistent after a VM reboot.

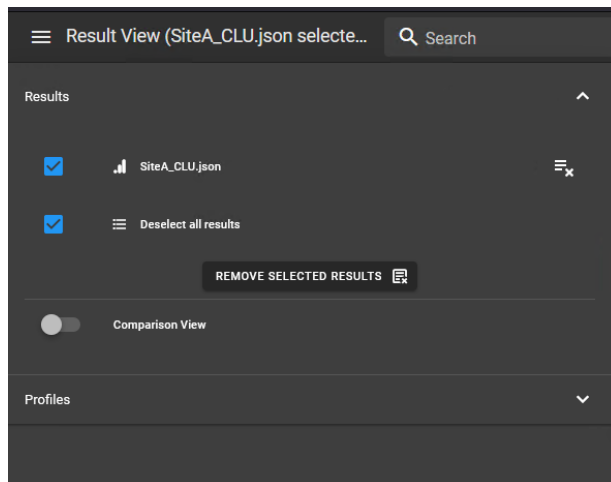
1. Navigate to http://<STIG_FQDN_IP>:8080



2. Drag and drop either the “json” or “csl” files into the rectangular dotted area.
3. Review your data



4. By default, you can drop multiple files and they will all be consolidated to the one graph, however you can get a side by side comparison by toggling the “Comparison View”



Notes about the input file

Remember, unless you specifically specify a parameter, a vSphere input file with the following content WILL audit **everything in the vCenter**

vmhostName: "

cluster: "

allesxi: true

Choose whether to scan a single VM or all VMs in vCenter.

vmName: "

allvms: true

By default, the input file and the programming for the VM controls do not cater for auditing specific clusters. It's a single VM or ALL VM objects in a vCenter. This may be fixed in a later release to be able to specify to audit VMs in a specific cluster

References

[GitHub - vmware/dod-compliance-and-automation: Security hardening content for VMware solutions to US Department of Defense standards](#)

<https://github.com/mitre/heimdall2>

<https://www.cyber.mil/stigs/srg-stig-tools/>

<https://knowledge.broadcom.com/external/article/319670/toggling-the-vcenter-server-appliance-en.html>

<https://www.cybersaint.io/blog/nist-800-53-control-families>

<https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>

<https://github.com/mitre/crunchy-data-postgresql-16-stig-baseline>

<https://github.com/mitre/heimdall2?tab=readme-ov-file#features>

<https://hub.docker.com/r/mitre/heimdall-lite>

<https://knowledge.broadcom.com/external/article?legacyId=94398>